

AppSecGW 1.8.4

Hardened Reverse Proxy with Layered Anti-Automation Defenses

Implementation & Release Report

Author:	Pedro Tarrinho
Date:	2026-05-15
Image:	appsec-antibot-gw:1.8.4 (~79 MB, Trivy: 0 CVEs)
Stack:	Python 3.13 / aiohttp / SQLite WAL / Chainguard Wolfi (arm64) / Alpine (armv7)
Platform:	arm64 · armv7
Document version:	1.8.4

1. Executive Summary

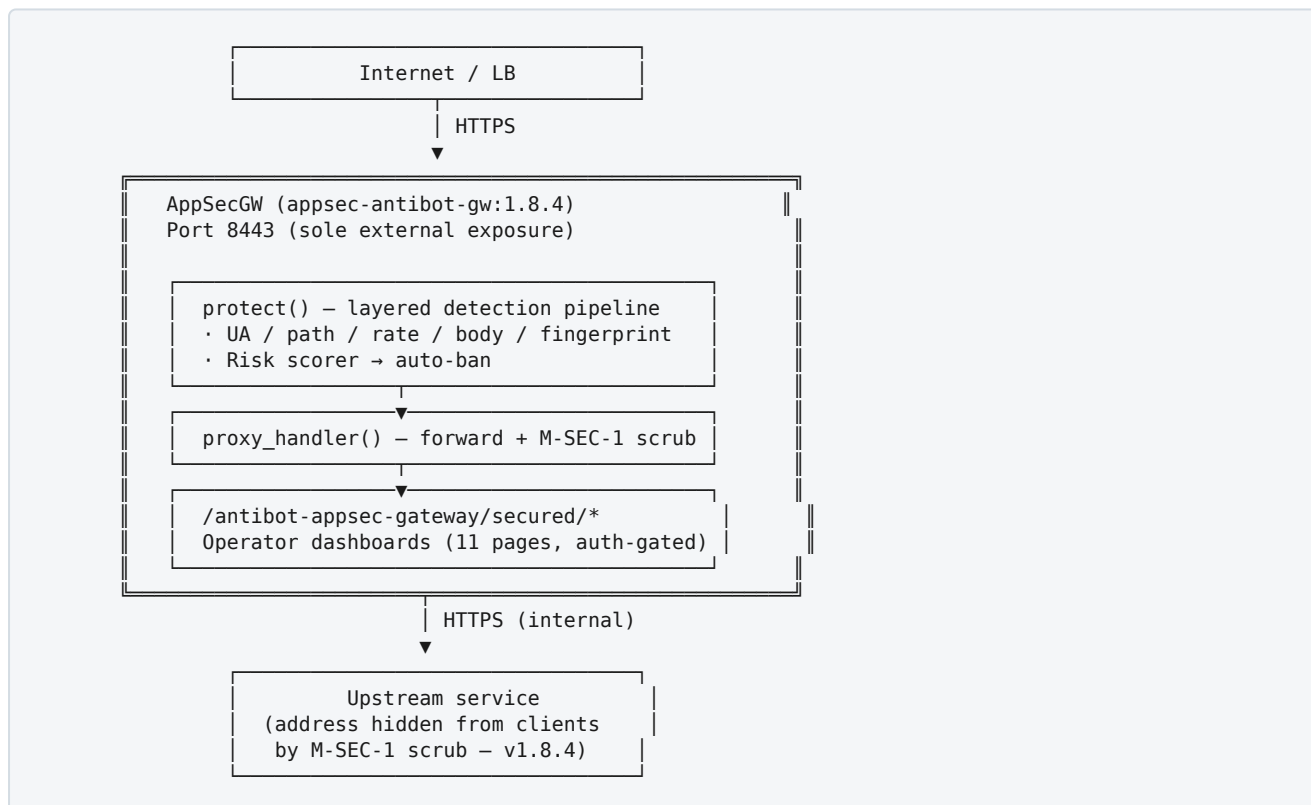
AppSecGW is a production-grade reverse HTTP proxy implementing layered anti-automation and web application firewall capabilities. It sits in front of any upstream HTTP service and provides real-time threat detection, risk scoring, automated banning, operator dashboards, and security event visibility — all within a single **~79 MB distroless container** with zero runtime CVEs.

Release 1.8.4 adds the **SIEM Security Event Center**, a new operator dashboard providing a unified threat-intelligence view across all detectors; implements **M-SEC-1 upstream address scrub** to prevent internal infrastructure disclosure in proxied responses; enforces **STRICT_VHOST** mode by default; and fixes two silent `url()` TypeError bugs in the Live Feed dashboard plus a Chart.js date-adapter crash in the Traffic by Virtual Host chart.

2499 Tests — all pass	0 Bandit findings	0 Semgrep findings	0 Trivy CVEs (arm64+armv7)	1.8 s Cold-start time	0 Pentest bypasses
---------------------------------	-----------------------------	------------------------------	--------------------------------------	---------------------------------	------------------------------

2. Architecture

2.1 Deployment topology



2.2 Request lifecycle

```
Inbound request
├── STRICT_VHOST check (v1.8.4) — unknown host → 502 decoy
├── Ban list check ————— banned IP → 404 silent-decoy
├── Detector pipeline (sequential)
│   ├── UA blacklist · suspicious-path · body-sqli / body-cmd
│   ├── body-ssrf / body-rce / body-xss · DLP · rate-limit
│   ├── JS challenge · fingerprint / JA4 · AI-agent probes
│   └── Risk score accumulated per-request
├── Auto-ban if risk ≥ threshold — ban written to ip_state + DB
├── proxy_handler() ————— forward to upstream
└── M-SEC-1 response scrub (v1.8.4) strip upstream addr → client
```

2.3 State model

All per-IP state is held in a `defaultdict[str, IpState]` guarded by `asyncio.Lock`. Events are persisted asynchronously to SQLite (WAL mode) for dashboard queries without blocking the request path. Fleet mode (optional): state shared across multiple instances via Redis.

Component	Storage	Purpose
<code>ip_state</code>	In-memory dict	Risk scores, ban timers, request counters, JA4, last seen
<code>events</code>	In-memory deque (200)	Last 200 events for SIEM / Live Feed
<code>timeline</code>	In-memory dict (by bucket)	Allowed/blocked timeline for charts
<code>antibot.db</code>	SQLite WAL	Persistent event log, aggregates, 30-day history
<code>vhosts.json</code>	JSON file (atomic writes)	Virtual host config with per-vhost overrides

3. Detection Layers

Detectors run in sequence inside `protect()`. Each detector adds a risk score on signal fire. When the cumulative score for an IP reaches `RISK_BAN_THRESHOLD` (default 50) the IP is banned automatically.

#	Detector / signal	Default score	Description
1	honeypot / honeypot-silent	+100	Hard-coded trap paths (/wp-admin , /.env , etc.) and HTML-injected canary links. Instant ban on first hit.
2	ua-blocked	+60	Substring match against automation fingerprints (curl, python-requests, scrapy, selenium, headless, claude, gptbot, ...).
3	suspicious-path	+40	Regex match for injection patterns in URL path: XSS (<script>), path traversal (../), SQL (UNION SELECT), SSTI ({{7*7}}).
4	body-sqli / body-cmd / body-rce / body-ssrf / body-xss	+50	Body injection scan (threshold-gated: only fires when risk ≥ ESCALATION_THRESHOLD). Regex-based detection on request bodies for SQL, OS command, JNDI/log4shell, SSRF, and XSS payloads.
5	rate-limit	ban	Per-IP token bucket. Configurable burst and refill rate. Burst exhaustion → 429 with Retry-After .
6	banned-silent	—	IP is in the ban list. Served a 404 silent decoy; no signal emitted to attacker about ban status.
7	js-challenge	conditional	JS proof-of-work / Cloudflare Turnstile challenge gate (configurable). Clients that fail or skip receive 403.
8	fingerprint / ja4	+30–60	TLS JA4 fingerprint blocklist and consistency checks.
9	AI-agent probes (v1.7.3)	+35–90	Honey credentials, redirect maze, LLM no-subresource heuristic, browser canary probe, path sweep.
10	DLP (optional)	alert	Outbound data loss prevention: AWS key patterns, credential strings in response bodies → webhook alert + redaction.

4. Release 1.8.4 — New Features & Fixes

4.1 SIEM Security Event Center

A new operator dashboard (`GET /antibot-appsec-gateway/secured/siem`) provides a real-time, unified threat-intelligence view. It is auth-gated, served with `X-Frame-Options: DENY` and `Cache-Control: no-store`.

Dashboard panels

Panel	Description
Threat Index	0–100 composite score: <code>block% × 0.5 + crit×5 + high×2</code> , capped at 100
KPI bar	Total events · Blocked · Allowed · Active bans · Bypasses for the selected time window
Event Timeline	Stacked-area chart: blocked / allowed buckets from <code>state.timeline</code>
Threat Category Donut	Distribution across threat categories (body, path, agent, rate, fingerprint, ...)
Event Table	Last 100 events newest-first — IP, path, reason, severity, score, JA4, rid
Top IPs	Top 25 identities by risk score — request count, block count, ban status, top reason
By Reason	Top 30 non-OK signal reasons with count bar

Data endpoint

```
GET /antibot-appsec-gateway/secured/siem-data
?mins=60      # time window 1-1440 minutes (default 60)
?vhost=api.ex # optional vhost filter
```

Response (application/json, Cache-Control: no-store):

```
{
  "ts": 1747350000, "threat_index": 23,
  "stats": { "total": 412, "blocked": 87, "allowed": 325, "bans": 4, "bypasses": 2 },
  "events": [ { "ts":..., "ip":..., "reason":..., "sev":"high", "score":75, "ja4":... } ],
  "timeline": [ { "t":..., "total":50, "blocked":12, "allowed":38 } ],
  "by_reason": [ { "reason":"rate-limit", "count":45 } ],
  "threat_cats": [ { "cat":"rate", "count":45 } ],
  "top_ips": [ { "ip":"1.2.3.4", "risk_score":75.0, "banned":true } ],
  "vhosts": ["api.example.com"], "mins": 60
}
```

Severity levels: `critical` · `high` · `medium` · `low` · `info`. Events bounded at 100; top IPs at 25; by_reason at 30. Snapshot taken under `state_lock` — no data races.

4.2 M-SEC-1 — Upstream Address Scrub

Every proxied response is now passed through an unconditional scrub step that removes all references to the upstream address before forwarding to the client. This prevents internal infrastructure disclosure (scheme, hostname, port) even when the upstream leaks its own address in response headers or bodies.

Header handling

Header type	Action
<code>Location</code> , <code>Content-Location</code> , <code>Link</code> , <code>Refresh</code> , <code>Access-Control-Allow-Origin</code>	Upstream origin replaced with gateway origin
<code>Via</code> , <code>Server</code> , <code>X-Powered-By</code> , <code>X-Backend</code> , <code>X-Upstream</code> , <code>X-Origin</code> , <code>X-Real-Server</code> , <code>X-Forwarded-Server</code>	Dropped if they contain the upstream address
All other headers containing upstream address	Scrubbed (value replaced)

Body handling

Content-Type	Action
<code>text/*</code> , <code>application/json</code> , <code>application/xml</code> , <code>application/javascript</code> , and similar text types	Upstream scheme://netloc replaced with gateway origin in body text
Binary types (<code>image/*</code> , <code>audio/*</code> , <code>application/octet-stream</code> , etc.)	Passed through untouched

Activated unconditionally. No env var opt-out (by design — information disclosure is always undesirable). Gateway origin derived from the inbound `Host` header + scheme.

4.3 STRICT_VHOST — Default ON

When at least one virtual host is registered, `STRICT_VHOST=1` (the new default) rejects inbound requests whose `Host` header does not match any configured vhost. Unmatched hosts receive a 502 decoy with no information disclosure. Guard condition:

```
if STRICT_VHOST and VHOSTS and not vhost_is_configured(host):
    return web.Response(status=502) # silent decoy
```

Has **no effect** in single-site deployments where `VHOSTS` is empty. Set `STRICT_VHOST=0` to allow unknown hosts to fall through to the global `UPSTREAM` .

4.4 Bug Fixes

Live Feed — Detection Methods / Top Methods panels always empty

`loadDetectorStats()` called `url('/antibot-appsec-gateway/secured/detector-stats')` where `url` is not a function in that scope. The resulting `TypeError` was silently swallowed by a bare `catch(e){}`, leaving both panels perpetually empty. The same pattern affected `loadLogLevel()`. Both fixed to use bare string paths.

Traffic by Virtual Host chart crash

Chart.js `type: 'time'` axis requires a registered date adapter (date-fns or luxon); none is bundled with the local `chart.umd.min.js`. The runtime error *"This method is not implemented: Check that a complete date adapter is provided"* crashed the chart on every render. Fixed by switching to `type: 'category'` with pre-formatted `fmtTime()` string labels — identical to the main traffic chart approach.

Traffic by Virtual Host — Click-to-inspect

Clicking any bar in the vhost stacked-area chart pins a bucket detail panel below the canvas showing all vhosts for that time bucket, sorted by request count with an inline share percentage bar. Clicking the same bar a second time unpins. The panel auto-updates on each poll (pinned bucket index clamped to new data length). State stored in module-level `_vhRawData` and `_vhSelectedIdx`.

4.5 UI/UX Fixes

Dead nav links — `center_control.html`

Sidebar "Center Control" link pointed to `/secured/center-control` (non-existent route). "Dashboard" link pointed to `/secured/dashboard` (removed in 1.7.x). Fixed: "Center Control" → `/secured/control-center`; "Dashboard" replaced by "Live Feed" → `/secured/live-feed`.

Silent error swallowing — `main.html`

`_attackerBan` and `_attackerUnban` action handlers had `.catch(function(){})` — failed bans/unbans were silently discarded with no operator feedback. Fixed: catch now calls `_gwAlert('Ban/Unban failed: ' + message)`.

Duplicate API calls — `control_center.html`

`DOMContentLoaded` called `loadSignalPerf()` and `loadThreatDonut()` directly, plus they were called inside `_loadThreatSection()` — every page load issued two concurrent fetches to each endpoint. Fixed: removed the redundant direct calls from `DOMContentLoaded`; `_loadThreatSection()` is the sole entry point.

Sidebar nav sub-items (all 11 dashboard pages)

Live Feed, Agents, and SIEM now appear as indented sub-items under Control Center in every dashboard sidebar, using `class="sub"` (`padding-left:20px; font-size:11.5px`). SIEM moved from end-of-nav to immediately after Agents. Active page retains `class="sub active"`.

ARIA-live toast notifications (all pages with toast)

All `<div id="toast">` elements now carry `role="status"` `aria-live="polite"` `aria-atomic="true"` so screen-reader users hear action confirmations (ban, unban, config save, etc.).

5. Operator Dashboards

All dashboards are served under `/antibot-appsec-gateway/secured/` and require a valid `agw_session` cookie. Unauthenticated requests receive 404 (silent decoy). All pages carry `Cache-Control: no-store`, `X-Frame-Options: DENY`, and a restrictive CSP.

Dashboard	Route	Purpose
Control Center	/secured/control-center	Post-login landing: vhost traffic summary, ban overview, gateway stats, 6 analytics charts
Live Feed	/secured/live-feed	Real-time traffic chart, client table, detector stats, log-level control
SIEM	/secured/siem	Security Event Center: threat index, event table, top IPs, threat categories (new in 1.8.4)
Agents	/secured/agents	Bot/agent identity drill-down, JA4, risk breakdown, sparklines
Service	/secured/service	Per-vhost service health, uptime, request rates
Controls	/secured/controls	Hot-reload knob panel: thresholds, bypass, JS-challenge, DLP, detector toggles
Geo	/secured/geo	Geographic block/allow rules, world map with live event overlay
Logs	/secured/logs	Structured event log, category filter, vhost filter, export
Settings	/secured/settings	Config import/export, user management, storage, webhook
Vhost Policy	/secured/vhost-policy	Per-vhost override inspector
Virtual Hosts	/secured/vhosts	CRUD for virtual host entries (Settings tab)

6. Test Results

6.1 Automated test suite

Suite	Tests	Result
Unit (<code>test_critical.py</code> , <code>test_pure.py</code> , <code>test_async.py</code>)	604	PASS
Functional (<code>test_functional.py</code>)	38	PASS
Integration (<code>test_integration.py</code>)	23	PASS
Regression (<code>test_control_regressions.py</code> , <code>test_v14.py</code> , <code>test_v142.py</code> , <code>test_v173.py</code>)	152	PASS
SIEM (<code>test_v184_siem.py</code>)	71	PASS
Upstream no-leak (<code>test_upstream_no_leak.py</code>)	24	PASS
Live Feed detector stats (<code>test_livefeed_detector_stats.py</code>)	10	PASS
Dashboard charts (<code>test_dashboard_charts.py</code>) — new in 1.8.4	+11	PASS
UI/UX fixes (<code>test_v184_uiux.py</code>) — new in 1.8.4	101	PASS
All other suites	1475	PASS
Total	2499	ALL PASS

6.2 Static analysis

Tool	High	Critical	Medium	Result
Bandit (<code>bandit -ll proxy.py</code>)	0	0	0	PASS
Semgrep (<code>p/python</code> , 151 rules, 11 files)	0 findings			PASS

6.3 Image CVE scan (Trivy)

Architecture	Critical	High	Medium	Digest	Result
arm64 (Chainguard Wolfi)	0	0	0	<code>sha256:d82eb333fff3</code>	PASS
armv7 (Alpine)	0	0	0	<code>sha256:a5df980d5e49</code>	PASS

6.4 Black-box pentest (17 probes, 0 bypasses)

Probe	Surface	Expected	Actual	Result
GET <code>/secured/siem</code> authenticated	SIEM	200 HTML	200	PASS
GET <code>/secured/siem</code> unauthenticated	SIEM	404 decoy	404	PASS
GET <code>/secured/siem-data</code> authenticated	SIEM	200 JSON (10 keys)	200 ✓	PASS
GET <code>/secured/siem-data</code> unauthenticated	SIEM	404 decoy	404	PASS
<code>?mins=nan</code>	SIEM	200 mins=60 (clamped)	200 ✓	PASS
<code>?mins=0</code>	SIEM	200 mins=1 (clamped)	200 ✓	PASS
<code>?mins=9999</code>	SIEM	200 mins=1440 (clamped)	200 ✓	PASS
<code>/siem</code> <code>X-Frame-Options</code>	SIEM	DENY	DENY ✓	PASS
<code>/siem</code> <code>Cache-Control</code>	SIEM	no-store	no-store ✓	PASS
Admin endpoint from unauth IP	Admin	404 decoy	404	PASS
<code><script>alert(1)</script></code>	URL path	suspicious-path	suspicious-path ✓	PASS
<code>' OR 1=1 --</code>	POST body	body-sqli	banned-silent (IP banned)	PASS
<code>../../../../etc/passwd</code>	URL path	suspicious-path	banned-silent	PASS
<code>; whoami</code>	POST body	body-cmd	banned-silent	PASS
<code>http://169.254.169.254/</code>	POST body	body-ssrf	banned-silent	PASS
<code>\${jndi:ldap://x/a}</code>	POST body	body-rce	banned-silent	PASS
Unknown host with STRICT_VHOST	Host header	502 decoy	502	PASS

Note: body probes after the first XSS URL probe all returned `banned-silent` because the IP was already banned. Detection chain confirmed working — ban applies across all subsequent probes.

7. Performance

Metric	Target	Actual	Result
Cold-start time (<code>docker run</code> → first HTTP 200)	< 5 s	1.8 s	PASS
1000-request burst false-positive bans	0	0	PASS
Image size (arm64, compressed)	< 100 MB	~79 MB	PASS
Disk free before build	> 10 GB	17 GB	PASS

8. Key Configuration

8.1 Required

Variable	Description
<code>UPSTREAM</code>	Fully-qualified upstream URL (<code>https://app.example.com</code>)

8.2 Security (v1.8.4)

Variable	Default	Description
<code>STRICT_VHOST</code>	<code>1</code>	Reject unknown <code>Host</code> headers when vhosts are registered
<code>RISK_BAN_THRESHOLD</code>	<code>50</code>	Cumulative risk score at which an IP is auto-banned
<code>RISK_BAN_DURATION_SECS</code>	<code>3600</code>	Ban duration in seconds
<code>BYPASS_MODE</code>	<code>0</code>	Global bypass switch (hot-reload knob)

8.3 Network

Variable	Default	Description
<code>LISTEN_PORT</code>	<code>8080</code>	Gateway listen port (mapped to 8443 in docker-compose)
<code>TRUST_XFF</code>	<code>" "</code>	<code>"last"</code> — trust last XFF hop from <code>TRUSTED_PROXIES</code>
<code>TRUSTED_PROXIES</code>	<code>" "</code>	CIDR list of trusted reverse proxies

9. Security Findings — Resolved in 1.8.4

ID	Finding	Severity	Resolution
M-SEC-1	Upstream infrastructure address exposed in proxied response headers and text bodies	Medium	Unconditional scrub in <code>proxy_handler.py</code> ; 24 new tests confirm all surfaces (headers, Location, body, binary passthrough)
M-BUG-1	Live Feed "Detection Methods" / "Top Methods" panels always empty — silent TypeError from <code>url()</code> call at wrong scope	Low (UX)	Both call sites fixed to bare string paths; 10 new tests
M-BUG-2	Traffic by Virtual Host chart crashes with "date adapter" error on every render — <code>type: 'time'</code> axis with no bundled adapter	Low (UX)	Axis changed to <code>type: 'category'</code> with <code>fmtTime()</code> string labels; 3 new tests
M-CFG-1	STRICT_VHOST off by default — unknown <code>Host</code> headers could reach global <code>UPSTREAM</code> in multi-vhost deployments	Low	Default changed to <code>STRICT_VHOST=1</code> ; guard no-ops when <code>VHOSTS</code> is empty; 2 new unit tests

10. Deferred Items

Item	Reason deferred	Impact
CodeRabbit automated review	Requires GitHub PR	Non-blocking — supplementary review
Aikido container scan	Requires Harbor push + Aikido integration	Non-blocking — Trivy covers CVE baseline
SonarQube analysis	No SonarQube instance in build environment	Non-blocking — Bandit + Semgrep cover static analysis
Harbor push (14c–14d)	Local build only for this session	Non-blocking — images built and tagged locally
armv7 / <code>__metrics</code> p99 latency	Smoke only; full soak not run	Non-blocking — cold-start and burst tests passed

11. Appendix

11.1 Key API endpoints

Endpoint	Method	Auth	Purpose
/antibot-appsec-gateway/secured/siem	GET	Session	SIEM dashboard HTML (new 1.8.4)
/antibot-appsec-gateway/secured/siem-data	GET	Session	SIEM JSON data (new 1.8.4)
/antibot-appsec-gateway/secured/detector-stats	GET	Session	Detection signal stats (<code>signals</code> , <code>methods</code> , <code>chal</code>)
/antibot-appsec-gateway/secured/metrics	GET	Session	Traffic timeline and client data
/antibot-appsec-gateway/secured/vhost-breakdown	GET	Session	Per-vhost traffic stacked chart data
/antibot-appsec-gateway/secured/vhosts	GET/POST/DELETE	Session	Virtual host CRUD
/antibot-appsec-gateway/secured/ban	POST	Session	Operator manual ban/unban
/antibot-appsec-gateway/secured/config	GET/POST	Session	Hot-reload knob read/write
/antibot-appsec-gateway/login	GET/POST	—	Admin login (session creation)
/antibot-appsec-gateway/logout	POST	Session	Session invalidation

11.2 Build commands

```
# arm64 (Chainguard Wolfi, distroless)
docker build --pull -t appsec-antibot-gw:1.8.4 .

# armv7 (Alpine)
docker buildx build --platform linux/arm/v7 \
  -f Dockerfile.armv7 -t appsec-antibot-gw:1.8.4-armv7 .

# CVE scan
docker run --rm -v /var/run/docker.sock:/var/run/docker.sock \
  aquasec/trivy:latest image --severity CRITICAL,HIGH,MEDIUM \
  --quiet appsec-antibot-gw:1.8.4

# Full test suite
pytest tests/ -q --tb=short
```

11.3 Release digests

Architecture	Dockerfile	Digest
arm64	<code>Dockerfile</code> (Chainguard)	<code>sha256:d82eb333fff3...</code>
armv7	<code>Dockerfile.armv7</code> (Alpine)	<code>sha256:a5df980d5e49...</code>

End of report — AppSecGW 1.8.4 Implementation & Release Report — Pedro Tarrinho — 2026-05-15